Appendix A: Red/Blue Team Exercise Report

OWASP Top 10: 2021 vs 2025 — Comparative Attack & Defense Analysis (OWASP Top 10：2021 與 2025 對比攻防分析)

Author (作者):	Mustafa
Project (專案):	Topic 15: Web Application Security Risk Detection and Remediation Demonstration System
Course (課程):	03CIT4067 Cybersecurity Project
Date (日期):	October 05, 2026
Classification (分類):	Internal — For Supervisor Review Only (內部文件 — 僅供導師審查)

Table of Contents (目錄)

1. Executive Summary (執行摘要)
2. Methodology (方法論)
3. Part I: OWASP Top 10:2021 Analysis (第一部分：2021 版分析)
4. Part II: OWASP Top 10:2025 Analysis (第二部分：2025 版分析)
5. Key Observations & Recommendations (關鍵觀察與建議)
6. References (參考文獻)

1. Executive Summary (執行摘要)

This report documents a comprehensive Red/Blue team exercise conducted against simulated web application environments. The objective was to evaluate the practical exploitability of vulnerabilities listed in both the OWASP Top 10:2021 and the newly released OWASP Top 10:2025, and to validate corresponding defense strategies. *(本報告記錄了一次針對模擬 Web 應用環境的全面紅藍隊演練。目標是評估 OWASP Top 10:2021 與新發布的 OWASP Top 10:2025 中所列漏洞的實際可利用性，並驗證相應的防禦策略。)*

Key findings (關鍵發現):

- **-** Broken Access Control (A01) remains the #1 risk in both 2021 and 2025, with SSRF now folded into this category in 2025. *(存取控制失效在 2021 和 2025 年均位居第一，SSRF 在 2025 年已被併入此類別。)*
- **-** Security Misconfiguration (A02) made the most dramatic jump, rising from #5 (2021) to #2 (2025), driven by cloud-native and container adoption. *(安全設定錯誤出現了最顯著的排名躍升，從 2021 年的第 5 位升至 2025 年的第 2 位，主要受雲端原生與容器化普及推動。)*

- **-** Software Supply Chain Failures (A03) is a new category at #3 in 2025, ranked #1 by the community survey with 50% of respondents placing it first. *(軟體供應鏈失效是 2025 年第 3 位的新類別，在社群調查中排名第一，50% 的受訪者將其列為首位。)*
- **-** Mishandling of Exceptional Conditions (A10) is a new and overdue addition in 2025, covering fail-open vulnerabilities that affect ~770k occurrences. *(異常條件處理失效是 2025 年新增且早該出現的類別，涵蓋影響約 77 萬次發生的 fail-open 漏洞。)*

2. Methodology (方法論)

Aspect (面向)	Description (描述)
Role (角色)	Red Team (Attacker) & Blue Team (Defender) / 紅隊（攻擊方）與藍隊（防禦方）
Environment (環境)	Simulated production codebases, deliberately vulnerable web applications, local Docker containers / 模擬生產環境程式碼、刻意存在漏洞的 Web 應用、本地 Docker 容器
Standards (標準)	OWASP Top 10:2021 and OWASP Top 10:2025 / OWASP Top 10:2021 與 OWASP Top 10:2025
Scope (範圍)	All 10 categories in each version / 每個版本的全部 10 個類別

3. Part I: OWASP Top 10:2021 Analysis (第一部分：2021 版分析)

A01:2021 — Broken Access Control (存取控制失效)

Red Team Findings: I logged in as a regular user and changed a URL parameter from 123 to 124. Suddenly I was looking at someone else's account details — email, address, order history — all of it. No exploit. No payload. Just changing a number. OWASP says 94% of tested applications had some form of this (OWASP Foundation, 2021). The scary part is how many forms it takes: IDOR (changing IDs in URLs), privilege escalation (regular user acting like admin), CORS misconfiguration (allowing unauthorized origins to access APIs), path traversal, and forced browsing. There is no single fix.

Blue Team Defense: Server-side authorization on every request. Deny by default. Record ownership checks. Do not trust anything the client sends.

A02:2021 — Cryptographic Failures (加密機制失效)

Red Team Findings: This used to be called 'Sensitive Data Exposure' but got renamed to focus on the root cause. I found Math.random() being used for password reset tokens in a simulated production codebase. That is a non-cryptographic random number generator. I collected a few token samples, figured out the seed, and predicted the next valid reset token. Account takeover — just like that. Other findings: MD5 for password hashing (trivially cracked), data transmitted over HTTP instead of HTTPS, hardcoded encryption keys in source code.

Blue Team Defense: Use bcrypt/scrypt/Argon2 for passwords. Use CSPRNG for tokens. TLS everywhere. Do not roll your own crypto.

A03:2021 — Injection (注入攻擊)

Red Team Findings: Injection dropped from #1 in 2017 to #3 in 2021, but it is still huge. I tested a diagnostic endpoint that took an IP address and ran ping. I sent 8.8.8.8; cat /etc/passwd. The shell executed both commands. I read the password file. SQL injection, NoSQL injection, OS command injection, LDAP injection, template injection — the list goes on. XSS got folded into this category in 2021, which makes sense as it is HTML/JavaScript injection.

Blue Team Defense: Parameterized queries. Output encoding. Avoid shell calls. Validate and sanitize everything.

A04:2021 — Insecure Design (不安全設計)

Red Team Findings: This was new in 2021, and one of the most important categories on the list. Insecure design is about flaws in the architecture itself — not bugs in the code, but decisions made before any code was written. I tested a cinema booking system that allowed group discounts for 15+ people, but there was no rate limiting and no maximum. I scripted a request for 600 seats in one API call. The system accepted it. I locked up all the seats without paying (OWASP Foundation, 2021).

Blue Team Defense: Threat modeling. Security requirements in user stories. Rate limiting on expensive operations. Plausibility checks at every tier.

A05:2021 — Security Misconfiguration (安全設定錯誤)

Red Team Findings: I found default credentials admin:admin on an admin panel. Database port wide open. Debug mode on, spitting out stack traces that told me exactly what framework version was running and where the internal files lived. OWASP says 100% of tested applications had some form of misconfiguration (OWASP Foundation, 2021). That is not a vulnerability — that is negligence.

Blue Team Defense: Change defaults. Disable debug in production. Remove unnecessary features. Configure security headers. Audit cloud permissions.

A06:2021 — Vulnerable and Outdated Components (易受攻擊與過時的組件)

Red Team Findings: I checked a simulated app's dependencies and found an old version of a popular library with a published remote code execution vulnerability. The app was running it in production. Nothing was scanning for this. Equifax is the textbook case: unpatched Apache Struts, 147 million records exposed. Log4Shell was the same story at massive scale.

Blue Team Defense: Inventory your dependencies. Scan for known CVEs. Update regularly. Know what is in your software.

A07:2021 — Identification and Authentication Failures (識別與驗證機制失效)

Red Team Findings: Credential stuffing. I took a leaked username/password list from a previous breach and ran it against a simulated login endpoint. No rate limiting. No MFA. Multiple accounts matched. This category covers weak password policies, missing MFA, session management flaws, and credential stuffing.

Blue Team Defense: MFA everywhere. Rate limiting on login. Breach-list checks. Secure session management.

A08:2021 — Software and Data Integrity Failures (軟體與資料完整性失效)

Red Team Findings: I sent a maliciously constructed Java serialized object to an endpoint that accepted serialized data. The app deserialized it without checking the source. Remote code execution. This also covers insecure CI/CD pipelines and auto-update mechanisms that do not verify signatures.

Blue Team Defense: Do not deserialize untrusted data. Verify signatures. Secure your build pipeline.

A09:2021 — Security Logging and Monitoring Failures (安全日誌與監控失效)

Red Team Findings: I slowly extracted data over several weeks through legitimate API endpoints. No alerts. No anomaly detection. Nobody noticed. The IBM Cost of a Data Breach 2025 report puts the global mean time to identify and contain a breach at 241 days (IBM Security, 2025). That is eight months of an attacker moving around inside your network, and you do not know. This category is underreported because you cannot file a CVE for an alert that never fired.

Blue Team Defense: Centralized logging. Real-time alerting. Incident response playbooks. Do not just log — alert.

A10:2021 — Server-Side Request Forgery (SSRF, 伺服器端請求偽造)

Red Team Findings: I tested an endpoint that took a URL for 'image processing.' I pointed it at http://169.254.169.254/latest/meta-data/ (the cloud metadata endpoint). The app fetched it and returned the response. Cloud credentials exposed.

Blue Team Defense: URL allowlists. Validate and restrict what the app can fetch. Do not trust user-supplied URLs.

4. Part II: OWASP Top 10:2025 Analysis (第二部分：2025 版分析)

A01:2025 — Broken Access Control (存取控制失效)

Change from 2021: Still #1. The big change: SSRF got folded into this category. A01 now covers IDOR, privilege escalation, CORS misconfiguration, path traversal, forced browsing, and SSRF.

Red Team Findings: The persistence of this category at #1 indicates that the industry is still not doing the fundamental work of checking permissions on every single request. Features are being shipped faster than they are being secured.

Blue Team Defense: Same as 2021, plus SSRF URL allowlists.

A02:2025 — Security Misconfiguration (安全設定錯誤)

Change from 2021: Jumped from #5 to #2 — the most dramatic ranking change on the list. Cloud-native and container adoption expanded the attack surface massively. OWASP's 2025 data shows 16 CWEs mapped here, max incidence rate 27.70% (OWASP Foundation, 2025).

Red Team Findings: I found the same issues as in 2021: default credentials, debug mode on, verbose errors. But now it is worse because cloud makes misconfigurations reproducible at scale. One bad Terraform template can deploy a thousand vulnerable instances.

Blue Team Defense: Automated hardening. Policy-as-code. Secure defaults. Continuous config monitoring.

A03:2025 — Software Supply Chain Failures (軟體供應鏈失效)

Change from 2021: New category at #3. Expanded from 'Vulnerable and Outdated Components' to cover the entire supply chain: dependencies, CI/CD pipelines, build tools, artifact repositories, developer workstations. Ranked #1 in the community survey (50% first-place votes).

Red Team Findings: I ran a dependency confusion test. Published a fake package with the same name as an internal library to a public registry. The build system pulled it without verifying origin. Backdoor installed. The numbers are brutal: 454,600 new malicious packages in 2025, up 75% from the year before. 30% of breaches now involve a third party, double from the previous year. The Bybit hack in 2025 — $1.5 billion — was a compromised CI/CD pipeline.

Blue Team Defense: SBOM. Dependency pinning. Signature verification. Private registries. CI/CD access control.

A04:2025 — Cryptographic Failures (加密機制失效)

Change from 2021: Dropped from #2 to #4. OWASP's 2025 data shows this category has 2,185 total CVEs and an average weighted exploit score of 7.23 (OWASP Foundation, 2025).

Red Team Findings: I still find Math.random() in production code. I still find weak hashing. The ranking likely dropped because people started paying attention to the symptom (data exposure) rather than because crypto implementation actually improved.

Blue Team Defense: Same as 2021. Use modern algorithms. Use CSPRNG. Encrypt everything.

A05:2025 — Injection (注入攻擊)

Change from 2021: Dropped from #3 to #5. Frameworks handle this better now. Parameterized queries are the default in most ORMs. However, the CVE count is still the highest: 62,445 CVEs, dominated by XSS (>30k) and SQL injection (>14k) (OWASP Foundation, 2025).

Red Team Findings: I still find command injection in diagnostic endpoints and admin panels. I still find SQL injection in legacy code. But I have to try harder now.

Blue Team Defense: Parameterized queries. Output encoding. CSP. Avoid shell calls.

A06:2025 — Insecure Design (不安全設計)

Change from 2021: Dropped from #4 to #6. Not because design failures got rarer, but because Misconfiguration and Supply Chain leapfrogged it. Spans 39 CWEs and 7,647 CVEs (OWASP Foundation, 2025).

Red Team Findings: The cinema booking attack still works. Business logic abuse is still everywhere. The key insight: an insecure design cannot be saved by perfect code.

Blue Team Defense: Threat modeling on critical flows. Security requirements in user stories. Paved-road libraries.

A07:2025 — Authentication Failures (驗證機制失效)

Change from 2021: Stayed at #7, but renamed. Dropped 'Identification' from the title to better match the 36 CWEs it actually covers (OWASP Foundation, 2025).

Red Team Findings: Credential stuffing still works. MFA helps. But attackers adapt.

Blue Team Defense: MFA. Rate limiting. Breach-list checks. Secure sessions.

A08:2025 — Software or Data Integrity Failures (軟體或資料完整性失效)

Change from 2021: Stayed at #8. Focuses on trust and integrity at a lower level than supply chain failures.

Red Team Findings: Insecure deserialization still exists. CI/CD pipeline integrity still matters. Auto-update mechanisms without signature verification still get exploited.

Blue Team Defense: Signature verification. No untrusted deserialization. Signed updates.

A09:2025 — Security Logging & Alerting Failures (安全日誌與警示失效)

Change from 2021: Stayed at #9, but renamed. Added 'Alerting' to emphasize that logs nobody sees in time are a forensic tool, not a control (OWASP Foundation, 2025).

Red Team Findings: The IBM 241-day mean time to identify and contain a breach is the reality (IBM Security, 2025). We are logging, but we are not alerting. We are collecting data, but we are not acting on it.

Blue Team Defense: Real-time alerts. Anomaly detection. Incident response playbooks. Logs that fire.

A10:2025 — Mishandling of Exceptional Conditions (異常條件處理失效)

Change from 2021: New category. This is the most overdue addition to the list, covering 24 CWEs, ~770k occurrences, and 3,416 CVEs (OWASP Foundation, 2025).

Red Team Findings: I tested a fail-open vulnerability. Sent malformed requests that triggered unhandled exceptions in the authorization check. The code returned true instead of false when it crashed. The app let me in because it failed wrong. This is about what happens when things go wrong: crashes, fail-open conditions, partial transactions, resource exhaustion, raw error messages exposed to users. Distributed systems crash. They fail. The only question is whether they fail closed or fail open. Too many fail open.

Blue Team Defense: Fail closed. Transactional rollback. Bounded resources. No stack traces to users. Local handling at the point of failure. Global exception handler as safety net.

5. Key Observations & Recommendations (關鍵觀察與建議)

Observation (觀察)	Implication for Project (對專案的啟示)
A01 (Broken Access Control) persists at #1 across both versions.	Our demo system must prioritize IDOR and SSRF demonstrations with clear before/after remediation. (示範系統應優先展示 IDOR 和 SSRF，並提供清晰的修復前後對比。)
A02 (Security Misconfiguration) jumped to #2 due to cloud adoption.	We should include Docker/cloud misconfiguration scenarios in our vulnerable modules. (應在漏洞模組中加入 Docker/雲端設定錯誤的情境。)
A03 (Supply Chain) is entirely new and community-ranked #1.	We must integrate SBOM and dependency scanning tools (e.g., Snyk, pip-audit) into the platform. (必須將 SBOM 和依賴掃描工具整合到平台中。)
A10 (Exceptional Conditions) is new and covers fail-	We should build a custom Flask module specifically demonstrating fail-open vs fail-closed behavior.

open bugs.	(應建構一個自定義 Flask 模組，專門演示 fail-open 與 fail-closed 行為。)

6. References (參考文獻)

IBM Security. (2025). Cost of a data breach report 2025. IBM Corporation. https://www.ibm.com/reports/data-breach

OWASP Foundation. (2021). OWASP Top 10:2021: The ten most critical web application security risks. https://owasp.org/www-project-top-ten/

OWASP Foundation. (2025). OWASP Top 10:2025: The ten most critical web application security risks. https://owasp.org/www-project-top-ten/

— End of Appendix A (附錄 A 完) —